Ders 9 - Veritabanı Güvenliği ve Gömülü SQL

Ders 9 - Veritabanı Güvenliği ve Gömülü SQL

Genel Konular

- Oracle veritabanı güvenlik mekanizmaları
- Rol tabanlı erişim kontrolü (RBAC)
- GRANT/REVOKE işlemleri ve varyantları
- VPD (Virtual Private Database) / Satır Tabanlı Güvenlik
- Güvenlik etiketleri ve sınıflandırma seviyeleri
- Yıldız Özelliği (Star Property) ve Basit Güvenlik Özelliği
- Toplama saldırıları (Aggregation Attacks)
- Gömülü SQL (Embedded SQL) kavramları
- Üç uygulama mimarisi karşılaştırması

Hocanın Özellikle Vurguladığı Kısımlar

- WITH GRANT OPTION ile verilen yetkinin revoke edilmesi durumunda cascading davranışı
- WITH ADMIN OPTION'ın revoke edildiğinde cascading olmaması (farklılık)
- Güvenlik etiketleri: S (Secret), C (Confidential), TS (Top Secret), TC (Top Confidential)
- Star Property'nin write-down özelliği ve aggregate sorgularla veri sızıntısı riski
- Toplama saldırılarına örnek: Ahmet'in not ortalaması üzerinden bireysel bilgi çıkarma
- VPD'nin yetersiz kaldığı durumlarda TRIGGER ile güvenlik sağlamak
- Gömülü SQL'de ortak değişkenlerin (shared variables) iki nokta üst üste (::) ile tanımlanması
- SQLCA (SQL Communication Area) ve hata kodlarının kontrolü

Kısa Tekrar Notları

- GRANT privilege ON object TO user WITH GRANT OPTION → yetki verir, cascade eder
- GRANT role TO user WITH ADMIN OPTION → rol verir, cascade etmez
- VPD ile satır bazlı erişim sağlanır, etiketlerle sınıflandırma yapılır
- Star Property: Daha düşük seviyeye yazma izni varsa, aggregate sorgularla veri sızabilir
- Embedded SQL'de EXEC SQL ile SQL blokları, :: ile ortak değişkenler kullanılır
- Üç mimari: Embedded SQL (yavaş, esnek değil), Library-based (hızlı, esnek), Stored Procedures (hızlı, en az esnek)

Detaylı Açıklamalar

Rol Tabanlı Erişim Kontrolü (RBAC)

- Rollere yetki verilir, kullanıcılar rollere atanır
- Bir kullanıcı birden fazla rolden gelen birleşik yetkilere sahip olur
- Örnek: A rolü tablo1'i okuma yetkisi verir, B rolü tablo2'yi yazma yetkisi verir → kullanıcı hem A hem B rolündeyse her ikisine de erişir

GRANT/REVOKE İşlemleri

- **GRANT privilege ON table TO user WITH GRANT OPTION**: Kullanıcıya yetki verir, kullanıcı bu yetkiyi başkasına aktarabilir
- **REVOKE privilege FROM user CASCADE**: Yetkiyi geri alır, zincirdeki tüm alt yetkileri de iptal eder
- **WITH ADMIN OPTION**: Roller için kullanılır. Bir kullanıcıya rol verilir, o rolü başkasına atayabilir. Ancak REVOKE edildiğinde cascade davranışı göstermez (farklılık)

Güvenlik Etiketleri ve Sınıflandırma

- **S (Secret)**: Gizli
- **C (Confidential)**: Gizli (farklı seviye)
- **TS (Top Secret)**: En üst düzey gizlilik
- **TC (Top Confidential)**: En üst düzey gizlilik
- Her kullanıcı ve veri nesnesi bir güvenlik etiketine sahiptir
- Kullanıcı kendi seviyesindeki veya daha düşük seviyedeki verilere okuma yapabilir

Yıldız Özelliği (Star Property / Ride Property)

- Write-down özelliği: Bir kullanıcı daha yüksek seviyeden okuma yapabiliyorsa, daha düşük seviyeye yazabilir
- Bu özellik aggregate sorgularla veri sızıntısına neden olabilir
- Örnek: Ahmet'in not ortalaması 85.5 ise, bu bilgi aggregate sorgudan çıkarılabilir
- Çözüm: TRIGGER ile aggregate sorguları engellemek veya DBMS_RLS paketini kullanmak

Gömülü SQL (Embedded SQL)

- Genel amaçlı programlama dillerine SQL komutları gömülür
- `EXEC SQL` ile SQL blokları işaretlenir
- Declare section'ında ortak değişkenler tanımlanır
- `::` (iki nokta üst üste) ile ortak değişkenlere erişilir
- SQLCA (SQL Communication Area) hata kodlarını tutar
- SQL code 0 → başarılı, pozitif/negatif → hata

Üç Uygulama Mimarisi

1. **Embedded SQL (Gömülü SQL)**: Yavaş, compile zamanı uzun, esnek değil
2. **Library-based (Kütüphane Tabanlı)**: Hızlı, esnek, dinamik kütüphanelerle güncellenebilir
3. **Stored Procedures (Depolanan Prosedürler)**: Hızlı, en az esnek

---

Not: Bu özet Gemini Notebook kullanılarak ses kayıtlarından oluşturulmuştur.